12 Authorization context

This chapter covers

- the three-dimensional choice space for context: which signals, how they’re delivered, and how fresh they are
- How PIPs collect signals and PDPs assemble entities for policy evaluation
- Signal delivery models: tokens, queries, and hybrids using device-posture tokens at request time
- Managing freshness, caching, and revocation to balance assurance and performance
- Securing and normalizing signals using provenance, signatures, and an enterprise PIP with a Shared Signal Framework-style eventing system

Policies alone aren’t enough to make authorization decisions; they need context to turn abstract rules into concrete outcomes. Whether a request should be allowed depends on not only who asks and what they want but also a surrounding set of facts: Is the device compliant? Is the employee still active? Is the login risky? Is the customer’s account suspended? These trust signals provide the raw material for policies to work. Without them, even the most elegant policy language is useless.

Every authorization system must answer three questions about signals:

- Which signals matter? (employment status, device trust, MFA, geolocation, risk score, account balance)
- How should those signals be delivered? (embedded in tokens, fetched from APIs, pushed from event streams, gathered by local agents)
- How fresh do they need to be? (queried live, cached briefly, or embedded until token expiry)

Together, these questions form a three-dimensional choice space. Designing an authorization system means choosing a position in that space for each use